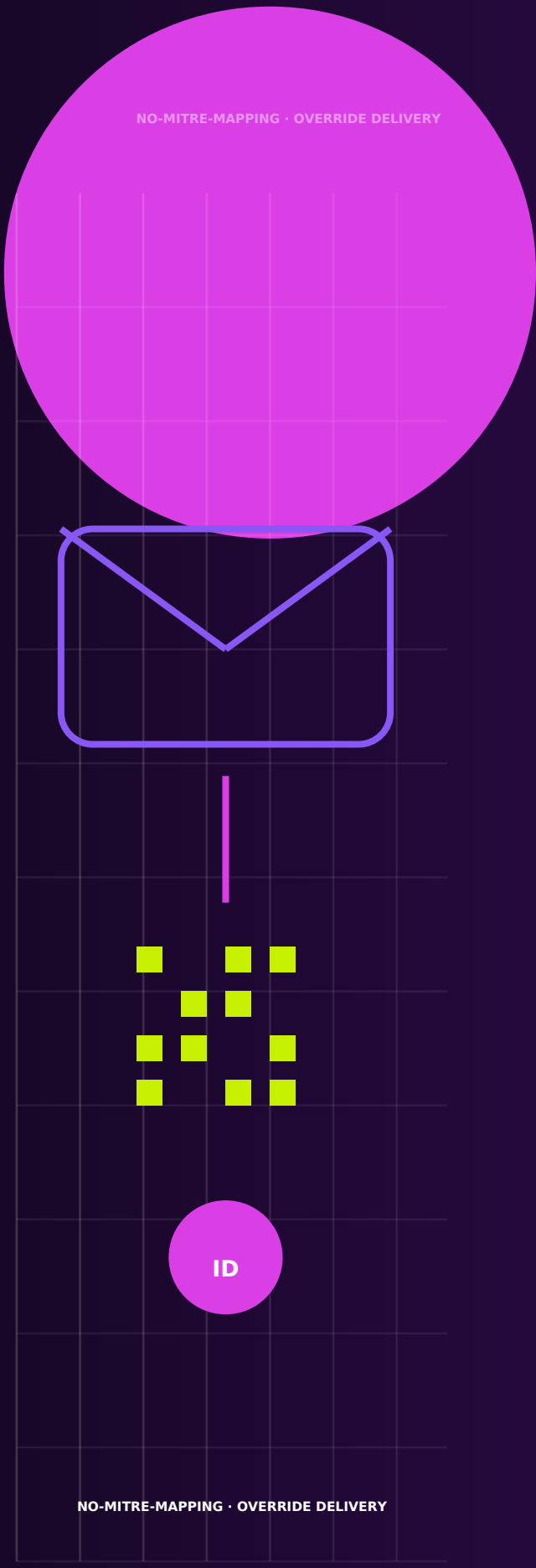
DETECTION THREAT LANDSCAPE

MICROSOFT 365 - DETECTED THREATS DELIVERED THROUGH TENANT OR USER ALLOW OVERRIDES

Defender XDR hunt for inbound messages with a threat verdict, explicit allow override and delivered outcome



HUNTING QUERY

CONFIDENCE: MEDIUM

REPORT TYPE
behavior

STATUS
Untested implementation sketch

PRIMARY PLATFORM
Microsoft Defender XDR

OPERATIONAL VALUE
9 / 10

01

Executive Assessment

Decision-grade summary with explicit evidence boundaries.

ASSESSMENT

DECISION

Publish as a Medium-confidence hunting query, not an alert. Investigate inbound messages for which Microsoft Defender recorded a threat verdict, an explicit organization- or user-level Allow override, and Delivered as the initial delivery action. Require policy ownership, current message state and interaction evidence before containment or promotion.

SOURCE-CONFIRMED

- Microsoft observed configured exceptions overriding protection for messages that failed authenticati...
- Microsoft's allowlist guide states that attackers exploit unnecessary allowlist gaps and provides the...
- The EmailEvents schema documents the fields and exact Delivered value used by the query...

ANALYST ASSESSMENT

- Combining verdict, explicit Allow and delivered outcome is more actionable than auditing allow...
- Latest delivery fields must be treated as enrichment because post-delivery remediation can...
- No ATT&CK technique is assigned because the generic control outcome does not establish a...

DETECTION ASSUMPTIONS

- The target tenant has Microsoft Defender for Office 365 Plan 2 and retains EmailEvents with populate...
- The literal Allow and Delivered values retain the documented semantics in the tenant and the...
- Policy owners can distinguish necessary exceptions, test messages and false-positive...

KEY FINDINGS

FINDING 1

Microsoft reported approximately 129 million malicious messages spoofing tracked business-service sender domains in Q3 2026; many were delivered after configured exceptions overrode protection. [C002]

FINDING 2

In September, overrides applied to 63 percent of the studied messages with a recorded security outcome, with tenant-level overrides accounting for most of them. [C003]

FINDING 3

EmailEvents exposes the threat verdict, organization/user override and delivery fields in one native schema; the hunt uses no IOC, threshold, join, body parsing or authentication-string assumption. [C004][C005][C006]

EVIDENCE BOUNDARY

The public research does not publish the affected tenants, individual policies, allow-entry scope or raw EmailEvents rows behind the aggregate override statistic. The number of delivered messages that users opened, acted upon or converted into compromise is not established. Target-tenant field completeness, benign prevalence, current-message-state reliability and policy ownership are unmeasured. A vendor-supported harmless simulation that reproduces all four predicates has not been confirmed in the target environment.

02

Threat Mechanics

Technical mechanism, observable transitions and supported scope.

ATTACK FLOW

TECHNICAL BACKGROUND

Microsoft's Q3 2026 email analysis found that attackers spoofed familiar business-service sender domains and that configured security exceptions could override malicious identification and failed authentication outcomes. An organization-level or mailbox-level allow entry can therefore convert a filtering verdict into delivery. Microsoft documents this decision surface in EmailEvents through ThreatTypes, OrgLevelAction, UserLevelAction and DeliveryAction. The query observes only the resulting control state: an inbound message with a non-empty threat verdict, an explicit Allow action and Delivered initial outcome. It does not parse AuthenticationDetails, infer why the exception existed, identify a brand, inspect message content or establish recipient action. [C002][C004][C005][C006][C007]

1

ATTACKER DELIVERY

An attacker sends an inbound message; the Q3 study includes large-scale spoofing of familiar business-service sender domains. Observable: Sender and authentication fields are triage context only; the generic hunt does not require a particular brand or authentication result.

2

SECURITY VERDICT

The Microsoft 365 filtering stack records malware, phishing or another threat verdict for the message. Observable: EmailEvents.ThreatTypes is non-empty, following the official override-analysis pattern.

3

EXCEPTION DECISION

An organization-level or user-level policy applies an explicit Allow action despite the threat verdict. Observable: OrgLevelAction or UserLevelAction equals Allow; associated policy fields identify the decision source for triage.

4

INITIAL DELIVERY

The service records Delivered as the initial delivery action for the recipient/message event. Observable: DeliveryAction equals Delivered; latest action and location are projected but not assumed to be unchanged.

5

RECIPIENT AND ACCOUNT OUTCOME

Opening, click-through, credential entry, malware execution and compromise are possible downstream outcomes but were not established for each delivered message. Observable: Separate click, post-delivery, identity, endpoint and incident telemetry is required; the hunt does not represent this phase.

03

Telemetry & Evidence Model

Minimum data contract and known visibility gaps.

DATA CONTRACT

PRIMARY PLATFORM

Microsoft Defender XDR. Select inbound EmailEvents rows with a non-empty threat verdict, explicit organization- or user-level Allow action and Delivered initial outcome.

FIELD / TABLE	STATUS	PURPOSE
EmailEvents	**Required**	Microsoft Defender for Office 365 processing records; requires the documented service prerequisite.
EmailDirection, ThreatTypes	**Required**	Limit results to inbound mail with a recorded filtering-stack threat verdict.
OrgLevelAction, UserLevelAction	**Required**	Establish that an explicit organization- or mailbox-level Allow action was recorded.
DeliveryAction	**Required**	Establish the documented Delivered initial outcome.
NetworkMessageId, RecipientEmailAddress, Timestamp	**Required**	Preserve a strong recipient/message pivot and event time for investigation.
OrgLevelPolicy, UserLevelPolicy, AuthenticationDetails, DetectionMethods	**Enrichment**	Explain the policy source, verdict mechanism and authentication context without inferring their content.
LatestDeliveryAction, LatestDeliveryLocation	**Enrichment**	Assess possible post-delivery remediation; these fields do not establish interaction.
URL-click, post-delivery, sign-in and endpoint telemetry	**Enrichment**	Determine whether the recipient interacted and whether any downstream compromise occurred.

KNOWN VISIBILITY GAPS

EmailEvents requires Defender for Office 365 and documented licensing Threat verdicts can be false positives or change after delivery Latest-state fields do not prove that a recipient saw or acted on the message The hunt does not cover undetected messages or exceptions not represented by the documented fields

04

Primary Detection Logic

Native query, explicit condition evidence and match meaning.

KQL

```
// Title: Microsoft 365 detected threat delivered through an explicit allow override
// Rule name: NO-MITRE-MAPPING - Detected threat allow override delivery
// Classification: Hunting query
// Maturity: hunting
// Status: Untested implementation sketch
// Primary platform: Microsoft Defender XDR advanced hunting
// Telemetry: Microsoft Defender for Office 365 EmailEvents
// MITRE ATT&CK: NO-MITRE-MAPPING - the match is a mail-control outcome, not a specific attacker technique
// Purpose: Find inbound messages that received a threat verdict, matched an organization- or user-level
// allow override, and were recorded as delivered.
// Logic: Require one EmailEvents row with inbound direction, non-empty ThreatTypes, an explicit Allow value
// in OrgLevelAction or UserLevelAction, and DeliveryAction == "Delivered". No IOC, threshold, join, rarity,
// content parsing, authentication-string assumption, or inferred post-delivery outcome is used.
// Match proves: Defender recorded a threat verdict, an explicit allow override, and delivered initial action
// for the same recipient/message event.
// Match does not prove: the verdict is correct, the message remains in the inbox, authentication failed,
// a tracked brand was spoofed, the recipient opened or acted on the message, or an account was compromised.
// False positives: necessary vendor exceptions, approved simulations, test policies, or false-positive verdicts.
// Limits: Defender for Office 365 Plan 2 and populated EmailEvents fields are required; policy ownership,
// current message location, recipient interaction, and benign prevalence require local investigation.
// Validation: execute the safe isolated controls and passive prevalence review in validation.md before promotion.
// Evidence claims: C002, C003, C004, C005, C006, C007, C008, C009, C010

EmailEvents
| where EmailDirection == "Inbound"
| where ThreatTypes != ""
| where OrgLevelAction == "Allow" or UserLevelAction == "Allow"
| where DeliveryAction == "Delivered"
| project
    Timestamp,
    NetworkMessageId,
    InternetMessageId,
    SenderMailFromAddress,
    SenderFromAddress,
    SenderDisplayName,
    RecipientEmailAddress,
    Subject,
    ThreatTypes,
    ThreatNames,
    DetectionMethods,
    ConfidenceLevel,
    AuthenticationDetails,
    DeliveryAction,
    DeliveryLocation,
    LatestDeliveryAction,
    LatestDeliveryLocation,
    OrgLevelAction,
    OrgLevelPolicy,
    UserLevelAction,
    UserLevelPolicy,
    EmailAction,
// ... complete 54-line query in hunting.kql
```

WHAT A MATCH PROVES

Defender recorded the threat verdict, explicit allow override and delivered initial action for the same recipient/message event.

WHAT IT DOES NOT PROVE

Correct verdict, failed authentication, sender spoofing, current inbox presence, recipient interaction, malware execution, account compromise or a specific ATT&CK technique.

MATURITY

Hunting query - Untested implementation sketch. Select inbound EmailEvents rows with a non-empty threat verdict, explicit organization- or user-level Allow action and Delivered initial outcome.

05

Triage & Hunting Playbook

Evidence-preserving workflow from match to disposition.

WORKFLOW

01

Preserve the raw EmailEvents row, query hash, Timestamp, NetworkMessageId and RecipientEmailAddress before policy or message remediation.

02

Open the message entity and establish which OrgLevelPolicy or UserLevelPolicy produced Allow; identify its owner, scope, justification, approval and expiry.

03

Review ThreatTypes, DetectionMethods and AuthenticationDetails as recorded data; do not assume failure or maliciousness from an empty or ambiguous value.

04

Compare initial and latest delivery fields and inspect EmailPostDeliveryEvents or Threat Explorer to determine whether ZAP or an analyst later moved or removed the message.

05

Correlate URL clicks, sign-ins, consent changes, endpoint activity and incidents for the recipient; absence of these layers leaves impact unknown.

06

Scope other messages sharing the policy, sender, cluster or message characteristics only after preserving the exact matched row and policy provenance.

DISPOSITION RULE

Escalate only when the evidence establishes the behavior described by the query. Correct verdict, failed authentication, sender spoofing, current inbox presence, recipient interaction, malware execution, account compromise or a specific ATT&CK technique.

06

False Positives & Validation

Overlap model, controlled checks and promotion gate.

QUALITY GATE

NECESSARY EXCEPTION FOR A LEGITIMATE VENDOR OR BUSINESS WORKFLOW AFTER A FALSE-POSITIVE VERDICT

Require a named policy owner, narrow scope, documented review, expiration and message-level provenance; do not silently suppress it in the query.

APPROVED SECURITY SIMULATION OR MAIL-FLOW TEST

Confirm the simulation identifier, test tenant or approved campaign record and verify that the exception is removed after testing.

STALE OR OVERLY BROAD TENANT/MAILBOX ALLOW ENTRY

Treat as a control gap rather than a benign false positive; review scope, remove unnecessary entries and rerun the hunt.

THREAT VERDICT LATER CORRECTED OR MESSAGE REMEDIATED POST-DELIVERY

Use latest delivery state, post-delivery events and analyst disposition; retain the initial override as policy-risk evidence.

VALIDATION SEQUENCE

- Confirm Defender for Office 365 Plan 2, EmailEvents availability and population of all four predicates using raw historical rows without changing policy.
- Measure 30 days of matches, resolve every policy owner and label necessary exceptions, simulations, false-positive verdicts and unexplained deliveries.
- In an isolated non-production tenant, create a temporary narrowly scoped Allow entry and use only a Microsoft-supported harmless simulation that is first confirmed to populate ThreatTypes.
- Run one allowed-threat positive and three negatives: allowed benign mail, detected-but-not-allowed mail and non-delivered detected mail; retain raw events and policy change records.
- Remove the temporary exception, purge test messages, verify policy rollback and record any telemetry delay or missing field.

SUCCESS

The unmodified query returns the safe positive with all four predicates and policy context, excludes each negative for the intended reason, and historical matches have bounded, attributable overlap.

REJECTION

Reject alert promotion if any required field is absent, simulation semantics differ from normal mail, necessary exceptions dominate without durable ownership, or current-message and policy context cannot be recovered.

PROMOTION GATE

Require retained safe controls, 30-day prevalence, complete field population, policy-owner accountability, bounded overlap, post-delivery triage and an approved response owner before designing alert logic.

07

Analyst Assessment & References

Coverage statement, open questions and source record.

FINAL

CONCLUSION

Fresh Microsoft telemetry shows that allow overrides can turn a threat verdict into message delivery at meaningful scale. EmailEvents provides a direct, documented and durable control-outcome hunt with no arbitrary threshold, but legitimate exceptions, false-positive verdicts and later remediation remain material. Keep the package at Medium-confidence hunting maturity until the isolated controls and tenant prevalence study are retained.

MITRE ATT&CK

NO-MITRE-MAPPING

PRIMARY AND AUTHORITATIVE REFERENCES

S001 Microsoft Threat Intelligence and Microsoft Defender Security Research Team - Email threat landscape: Q3 2026 trends and insights (2026-11-05)

hxxps://www[.]microsoft[.]com/en-us/security/blog/2026/11/05/email-threat-landscape-q3-2026-trends-and-insights/

S002 Microsoft - EmailEvents table in the advanced hunting schema (2026-09-02)

hxxps://learn[.]microsoft[.]com/en-us/defender-xdr/advanced-hunting-emailevents-table

S003 Microsoft - Review and remove unnecessary allowlist entries with Advanced Hunting (2026-07-14)

hxxps://learn[.]microsoft[.]com/en-us/defender-office-365/step-by-step-guides/review-allow-entries

OPEN QUESTIONS

The public research does not publish the affected tenants, individual policies, allow-entry scope or raw EmailEvents rows behind the aggregate override statistic. The number of delivered messages that users opened, acted upon or converted into compromise is not established. Target-tenant field completeness, benign prevalence, current-message-state reliability and policy ownership are unmeasured. A vendor-supported harmless simulation that reproduces all four predicates has not been confirmed in the target environment.

DOCUMENT CONTROL

Schema 2.0 | Layout 2.0 | Maturity hunting | Confidence Medium | No customer data | Evidence ledger required